

ICT2216/ICT2516C

Secure Software Development



Secure Software Requirements

Raymond Chan & Tram Truong Huu

Ransomware Attacks

THE BUSINESS TIMES

A ransomware attack hit a vendor to DBS. What is a ransomware attack and how does it affect companies?

Singapore was hit by 21 million cyberattacks originating from compromised servers in 2024

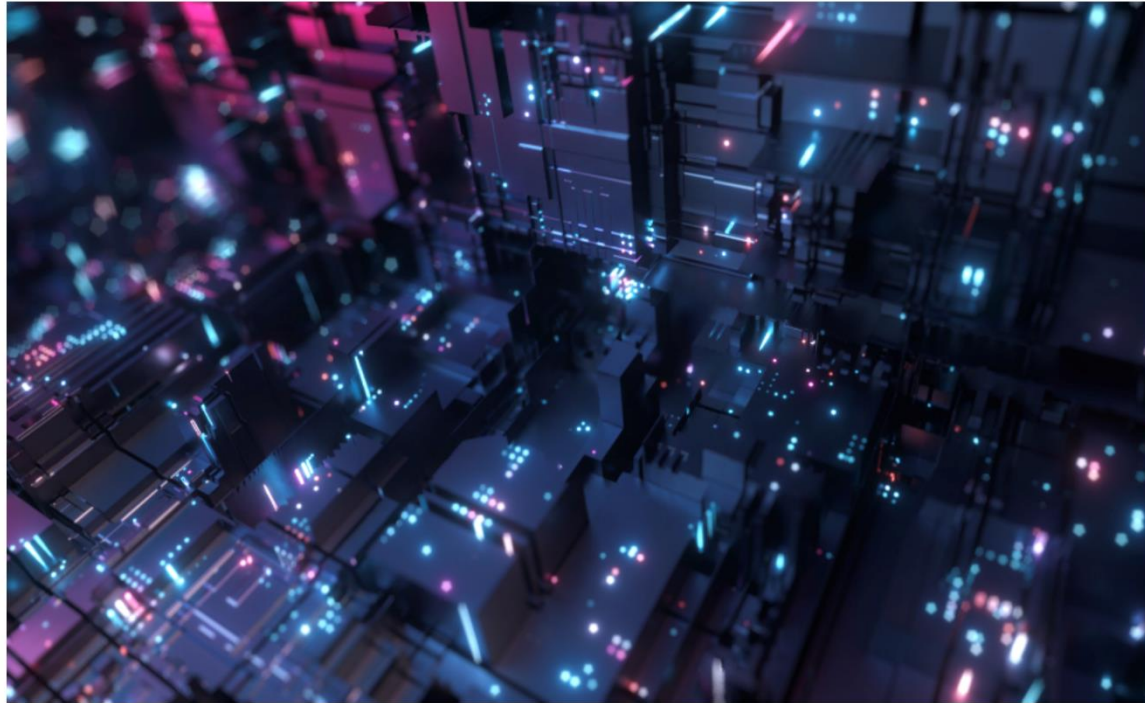
Romaine Chan

Published Tue, Apr 15, 2025 · 12:11 PM



Are you using MyRepublic?

MyRepublic reports data breach to customers



September 13, 2021

KEYWORDS cyber security / data breach / privacy / risk management

Order Reprints

MyRepublic, a telecommunications provider in Asia-Pacific with operations across Singapore, New Zealand and Australia, announced it discovered an unauthorized data access incident on August 29, 2021, and has moved to support its customers in mitigating any possible risk.

The unauthorized data access took place on a third-party data storage platform used to store the personal data of MyRepublic's mobile customers. The unauthorized access to the data storage facility has since been secured, and the incident has been contained.

The unauthorized data access took place on a third-party data storage platform used to store the personal data of MyRepublic's mobile customers.

The unauthorized access to the data storage facility has since been secured, and the incident has been contained.

Can you guess what is the third-party data storage platform they are using? And why?

Agenda

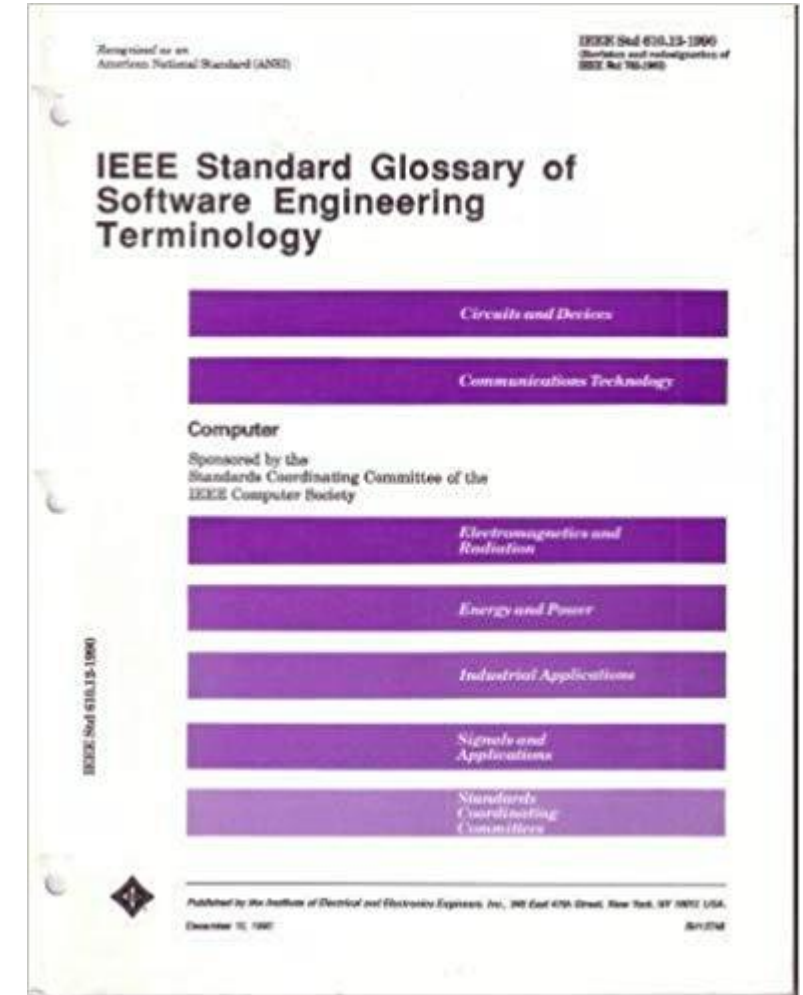
- Introduction to Secure Software Requirements
 - IEEE standard 729
- Requirement Process in Secure Software Development Lifecycle (SSDLC)
 - Feasibility Study
 - Secure Requirement Gathering
 - Secure Software Requirement Specification
 - Secure Software Requirement Validation
- Example
 - Payment Card Industry Software Security Framework
 - NIST Secure Software Development Framework (SSDF)

INTRODUCTION TO SECURE SOFTWARE REQUIREMENTS

Secure Software Requirements

A general definition defined by IEEE Standard 729:

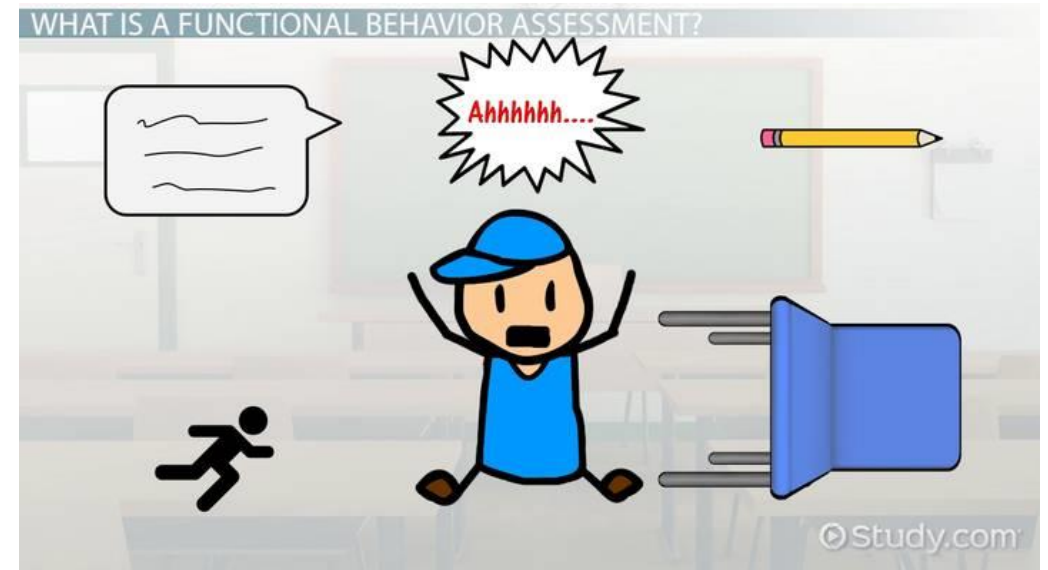
- A **condition** or **capability** needed by a user to solve a problem or achieve an objective.
- A **condition** or **capability** that must be met or possessed by a system... to satisfy a contract, standard, specification, or other formally imposed document.
- It has been said that
 - Without Software Requirements, **Software** will Fail.
 - Without Secure Software Requirement, **Organizations** will.



Software Requirements

Two main types of requirements

- Functional (Behavioral) Requirements --**WHAT**
 - Functions that the system must perform
- Non-Functional Requirements --**HOW**
 - Properties system must possess



Functional Requirements

Functionality and services the system should provide

- **Inputs** that are expected by the system
- **Outputs** that must be produced

Relationships between those inputs and outputs

Examples of Functional Requirements (LMS):

1. The LMS shall allow the administrator to create modules
2. The LMS shall allow the instructors to upload documents
3. The LMS shall provide appropriate viewers for the user to read documents in the document store.

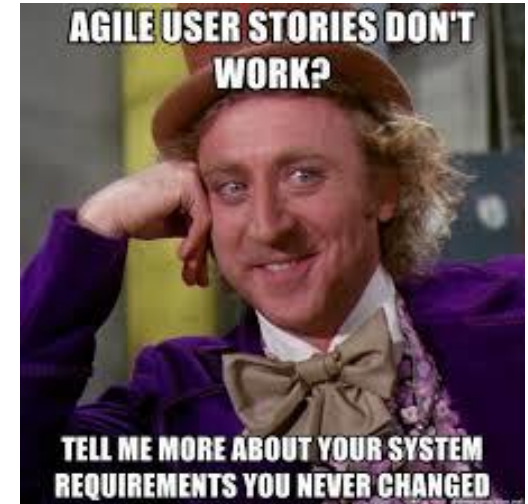


Non-Functional Requirements

Sometimes we called it as “User requirements” ...

Examples of Non-Functional Requirements

- The system shall run on Windows 7, Windows 10, and MacOS 10.4
- User logins will take at most 20 seconds from submitting credentials to seeing first screen
- The system will require less than 10 Mbps network speed to handle 100 concurrent users



Non-Functional Requirements

Application Domain	Relevant NFRs
Banking and Finance	Accuracy, confidentiality, performance. Security, usability
Education	Interoperability, performance, reliability, scalability, security, usability
Energy Resources	Availability, performance, reliability, safety, usability
Government and Military	Accuracy, confidentiality, performance, privacy, provability, reusability, security, standardizability, usability, verifiability, viability
Insurance	Accuracy, confidentiality, integrity, interoperability, security, usability
Medical/ Health Care	Communicativeness, confidentiality, integrity, performance, privacy, reliability, safety, security, traceability, usability
Telecommunication Services	Compatibility, conformance, dependability, installability, maintainability, performance, portability, reliability, usability
Transportation	Accuracy, availability, compatibility, completeness, confidentiality, dependability, integrity, performance, safety, security, verifiability

What is security requirement?

- *“Robust software security requirements help you lock down what your software does so that it can be used only as intended. Learn how to build your own”. By Jamie Boote*



Another definition by Open Security Architecture (OSA)

- **Secure Functional Requirements**, this is a security related description that is integrated into each functional requirement.
 - Typically, this also says what shall not happen.
 - This requirement artifact can be derived from misuse cases
- **Functional Security Requirements**, these are security services that needs to be achieved by the system under inspection.
 - Examples could be authentication, authorization, backup, server-clustering, etc.
 - This requirement artifact can be derived from best practices, policies, and regulations.



**Secure Functional?
Functional Security?**

Another definition by OSA (ct.)

Non-Functional Security Requirements, these are security related architectural requirements, like "robustness" or "minimal performance and scalability".

- This requirement type is typically derived from architectural principals and good practice standards.

Secure Development Requirements, these requirements describe required activities during system development which assure that the outcome is not subject to vulnerabilities.

- Examples could be "data classification", "coding guidelines" or "test methodology".
- These requirements are derived from corresponding best practice frameworks like "Comprehensive, Lightweight Application Security Process (CLASP)".



Login case

- Learnt in INF2001 (Introduction to Software Engineering)
 - Functional Requirements
 - Non-functional Requirements
- News in ICT2216/ICT2516
 - Secure Functional Requirements
 - Functional Security Requirements
 - Meeting CIA-AAA requirements
 - Non-functional Security Requirements

REQUIREMENT PROCESS IN SECURE SOFTWARE DEVELOPMENT LIFE CYCLE (SSDLC)

Requirement Process in SSDLC

- Feasibility Study
- Secure Requirement Gathering
- Secure Software Requirement Specification
- Secure Software Requirement Validation



Feasibility Study

Any discussion about software security should start with:

- The stakeholders
- Their assets
- The threats to these assets
- Attacker model (employees, customers, script kiddies, criminals, NSA or APTs)

Sources for security requirements:

- Software functionality
- Policies, standards, guidelines, patterns and practices to comply with
- Regulations, compliance initiatives



Secure Requirement Gathering

Typical Security Requirements:

1. Confidentiality
2. Integrity
3. Availability
4. Authentication
5. Authorization
6. Accountability



Confidentiality

Sensitive information should not be leaked to unauthorized parties

- Privacy for individuals
- Confidentiality for data

We need to consider controls to ensure confidentiality is ensured when Data is at Rest, In-Transit and also when it is processed.

Security Checklist should contain specifications required to implement these like, Protocols to Use, Encryption Strength, usage of Processes ensuring confidentiality like Random Number Generator, etc.

SANS - Securing Web Application Technologies Checklist



Securing Web Application Technologies [SWAT] Checklist

The SWAT Checklist provides an easy to reference set of best practices that raise awareness and help development teams create more secure applications. It's a first step toward building a base of security knowledge around web application security. Use this checklist to identify the minimum standard that is required to neutralize vulnerabilities in your critical applications.

ERROR HANDLING AND LOGGING



DATA PROTECTION



CONFIGURATION AND OPERATIONS



AUTHENTICATION



SESSION MANAGEMENT



INPUT AND OUTPUT HANDLING



ACCESS CONTROL



Data requirements

- What data the application needs to store?
 - Personal data?
 - Finance?
 - Communication?
 - Credit card information?
- Personal Data Protection Act has to be considered!

Data requirement - Example

Student Registration Form
Fill out the form carefully for registration

Student Name

First Name Middle Name Last Name

Birth Date **Gender**

Month Day Year

Address

Street Address

Street Address Line 2

City State / Province

Postal / Zip Code Country

Student E-mail

ex: myname@example.com

Mobile Number

All the App should follow the same? Agree?

Personal Data Protection Act

Consent Obligation	Purpose Limitation Obligation	Notification Obligation	Access and Correct Obligation	Accuracy Obligation
You must obtain the consent of the individual before collecting, using or disclosing his/her personal data for a purpose	You may collect, use or disclose personal data about an individual only for a purpose	You must notify the individual of the purpose for which it intends to collect, use or disclose	Upon request: 1) You must provide personal data in the possession and how it may have been used 2) Correct an error or omission in the personal data in possession	You must make a reasonable effort to ensure the personal data is accurate and complete

Protection Obligation	Retention Limitation Obligation	Transfer Limitation Obligation	Openness Obligation
You must protect personal data in its possession by making reasonable security arrangements	You must cease or remove to retain documents containing personal data that can be associated with individuals	You must NOT transfer personal data to a country outside of Singapore except in accordance with the requirements prescribed under the PDPA.	You must implement the necessary policies and procedures and make them publicly available.

Data leakage

Information can be leaked directly or via side channels

- Direct
 - Alice hacking into the bank account to see Bob's balance
- Indirect (side channel)
 - Alice determines that Bob has a bank account at DBS by noticing the shorter delay on login failure

Can you think of
other attacks?

Data leakage cases - SingHealth

Massive SingHealth Data Breach Caused by Lack of Basic Security

The lessons learned from Singapore's breach serve as a reality check to U.S. health organizations still failing to educate users, apply patches, and other common security methods.



By Jessica Davis



January 10, 2019 - Singapore's July 2018 personal data breach of 1.5 million SingHealth patients, including Prime Minister Lee Hsien Loong, was caused by bad system management, a lack of employee training, and other major flaws, according to the 454-page report **released** today by the investigation committee.

The committee was formed shortly after the 2018 breach, which included the personal information of patients, along with the medical data of about 160,000 patients. They held 22 hearings shortly after, which revealed the breach went on about a year between August 2017 and July 2018.

Among the host of SingHealth failures, the committee found Integrated Health Information System (IHIS), the IT agency responsible for the public health system's IT and security, lacked adequate cybersecurity awareness, resources, and training to properly respond to the cyberattack.

Data leakage cases - SingHealth

- This was highlighted by their inaction when the **properly identified suspicious activity around login attempts** on its database but failed to categorize the attempts as a cyberattack.
- It lacked **an incident reporting framework**, and staff were unfamiliar with security policies, which meant they were unaware of that the issue needed to be reported to Singapore's Cyber Security Agency.

Integrity requirement

- Prevention against unauthorized modifications
 - **System integrity**
 - **Data integrity**
- Integrity requirements is needed to ensure Reliability and Accuracy of the information.
- Implementation of Security Controls like **Hashing, Digital Signatures** assist in ensuring **Integrity**. Specifications like Protocols, Data Randomness Strength (e.g., Salt Length) etc. should be captured as a part of Security Checklist.
 - e.g., released software should provide the recipient with a **computed checksum** and **the hash function used to compute the checksum**, so that the recipient can validate its accuracy and completeness.

- Do you think download the software in official websites is always safe?

Popular BitTorrent Client Transmission Gets Infected With Malware Again

 Christina Warren
8/30/16 4:00pm • Filed to: NOT AGAIN ✓

 45.2K  50  9    



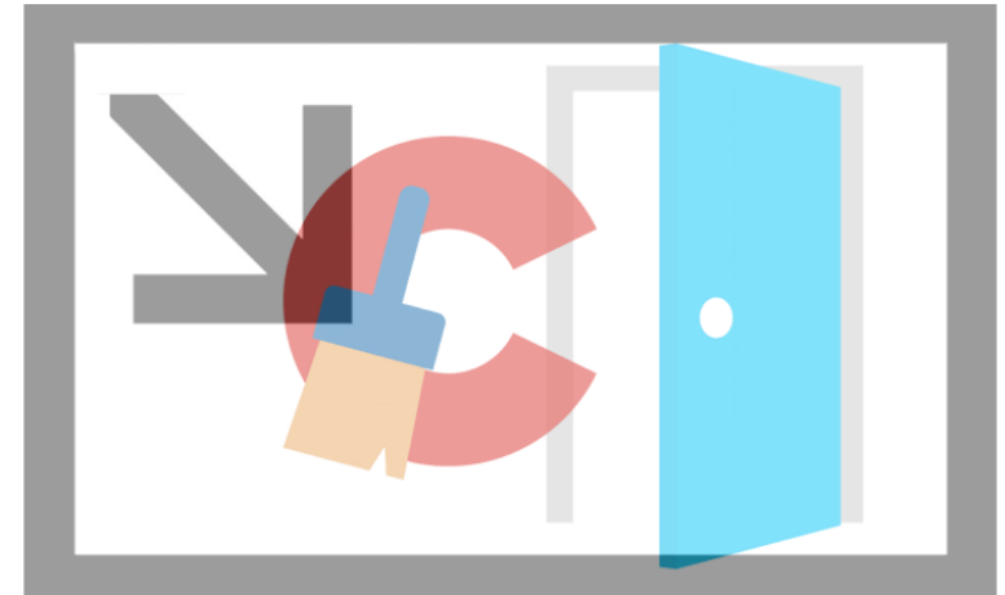
For the second time in five months, the Transmission BitTorrent client for Mac has been infected with malware.

Inside the CCleaner Backdoor Attack

Author:
Michael Mimoso
October 5, 2017
/ 5:18 am

minute read

Share this article:



Two members of Avast's threat intelligence team shared new information about the CCleaner backdoor attack.

MADRID—As the investigation continues into the backdoor planted inside CCleaner, two members of parent company Avast's threat intelligence team said today the desktop and cloud versions of the popular software contained different payloads.

OWASP – Security Code Checklist

OWASP Secure Coding Practices Checklist

This is a copy of the SCP checklist. For the project, see [OWASP Secure Coding Practices - Quick Reference Guide](#).

[hide]

- 1 Input Validation
- 2 Output Encoding
- 3 Authentication and Password Management
- 4 Session Management
- 5 Access Control
- 6 Cryptographic Practices
- 7 Error Handling and Logging
- 8 Communication Security
- 9 System Configuration
- 10 Database Security
- 11 File Management
- 12 Memory Management
- 13 General Coding Practices

Input Validation

1. Conduct all data validation on a trusted system (e.g., The server)
2. Identify all data sources and classify them into trusted and untrusted. Validate all data from untrusted sources (e.g., Databases, file streams, etc.)
3. There should be a centralized input validation routine for the application
4. Specify proper character sets, such as UTF-8, for all sources of input
5. Encode data to a common character set before validating (Canonicalize)
6. All validation failures should result in input rejection
7. Determine if the system supports UTF-8 extended character sets and if so, validate after UTF-8 decoding is completed
8. Validate all client provided data before processing, including all parameters, URLs and HTTP header content (e.g. Cookie names and values). Be sure to code
9. Verify that header values in both requests and responses contain only ASCII characters

Prof Raymond Chan
will talk more about
this in the second
half of the module:
static code analysis

Availability requirement

- Availability Requirements ensures protection against unwanted destruction or disruption of services.
- These are tricky requirements and should be captured as a part of **Service Level Agreement (SLA)** components like measurement of **Maximum Tolerable Downtime [MTD]** and **Recovery Time Objective [RTO]**.
- Throw this to the VM Service Provider?! 😊

DDoS cases

(Distributed) Denial of Service (DoS) attacks attempt to compromise the availability of the system

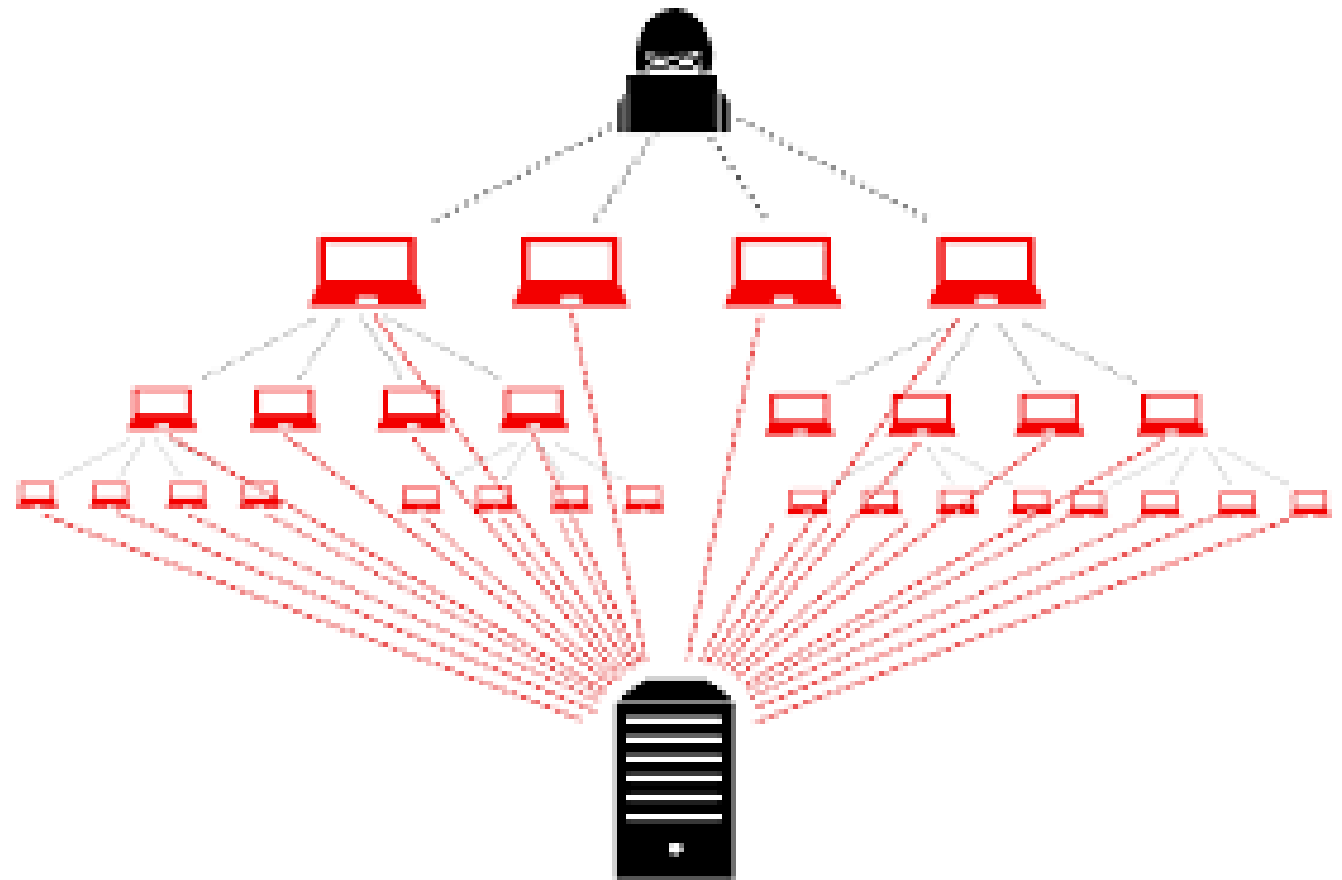
- By flooding system with useless work
- Or cutting off access to the network
- Or triggering an infinite loop (non-termination)

Question time

- How to define availability requirement?
- How to mitigate DDoS attack?

Mitigate DDoS attack

- DNS load balancing
- Server load balancing
- Content Distribution Network
- Firewall?
 - Layer 3: Network Firewall
 - Layer 5 (7): App Firewall
- **HIDE ALL IP ADDRESSES**



Examples of Availability requirements

- *The software shall ensure high availability of **five nines (99.999%)***
- *The number of users at any one given point of time who should be able to use the software can be up to **300 users**.*
- *Software and data should be replicated across data centers to provide **load balancing and redundancy**.*
- *Mission critical functionality in the software should be restored to normal operations within **1 hour of disruption**;*
- *Mission essential functionality in the software should be restored to normal operations within **4 hours of disruption**;*
- *Mission support functionality in software should be restored to normal operations within **24 hours of disruption**.*

Authentication requirement

- What information you need to authenticate a person?
- 2FA?

Something You Know



Username, password, PIN or security questions

Something You Have



Smartphone, one-time passcode or Smart Card

Something You Are



Biometrics, like your fingerprint, retina scans or voice recognition

2 factor authentication (2FA)

- Passwords can be weak
- Biometric can be too invasive to use
- Users can lose what they have (e.g., smartphone)
- Use **2 or more of these** to authenticate
 - e.g., online banking requires a password and access token (or OTP on smartphone)
 - SingPass two factor authentication

Password Requirement

- How to **handle** user's password?
- How to ensure the **complexity** of the password?
- **Password expiry policy?**
- **Forgot Password requirement**

Set password

Create password

Password requirements

- ✗ A minimum of 7 characters
- ✗ An UPPERCASE letter
- ✗ A lowercase letter
- ✗ A number or symbol

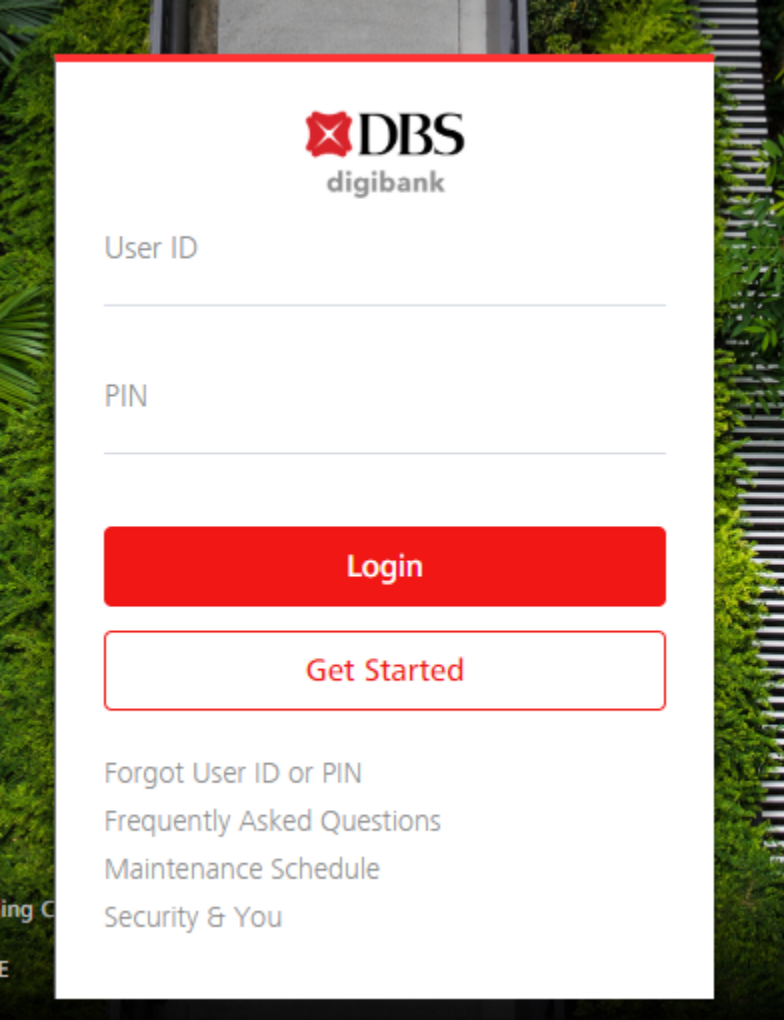
Choose password

[Need help logging in?](#)

Set password

Bad example

- 6 digits...



DBS
digibank

User ID

PIN

Login

Get Started

[Forgot User ID or PIN](#)

[Frequently Asked Questions](#)

[Maintenance Schedule](#)

[Security & You](#)

Usability vs Security!

No more complex password?



Why NIST Wants You to Remove Complexity from Your Password Policies

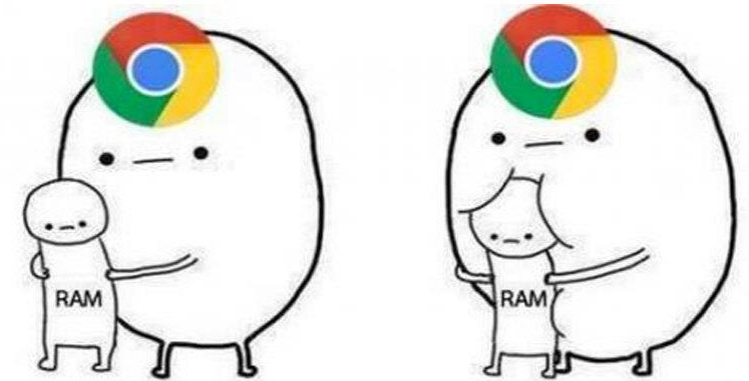
 by Rich Campagna on June 8, 2020

8 characters, special symbol, lower, upper, no repeating and a 90 day max. Try singing the de facto standard password policy and it sounds remarkably similar to the popular McDonald's Big Mac song of the 80's (for those too young, or too old, to remember, "two all beef patties, special sauce, lettuce, cheese, pickles, onions on a sesame seed bun)."

- What is the problem of complex password policy?

Why no more complex password policy?

- More passwords written down.
- More passwords reused (the average enterprise password is reused 2.7 times).
- Predictable “complexity,” that diminishes the point of complexity
- Example: r@Ymond1



New NIST password guideline

- 8 character minimum
- No complexity or special character requirements
- No password expiration
- Check against dictionaries and lists of previously breached passwords



GUIDELINE LEVELS

- **REQUIRED** (shall)
- **IMPORTANT** (should)
- **DESIRABLE** (may)

Ban "commonly-used, expected, or compromised" passwords

REQUIRED

NIST requires organizations to identify "commonly-used, expected, or compromised" passwords and, if selected, force users to reset them. According to NIST, these include, but are not limited to:

- Passwords obtained from previous breach corpuses.
- Dictionary words.
- Repetitive or sequential characters (e.g. 'aaaaa', '1234abcd').
- Context-specific words, such as the name of the service, the username, and derivatives thereof.

Aided by users' bad password habits, criminals actively use these types of common and compromised passwords in account takeover attacks. Of the 53,000 security incidents covered in the 2018 Verizon Breach Report,¹ 48 percent involved stolen credentials.

Following NIST guidance to restrict usage of weak or exposed passwords is the best thing organizations can do to protect themselves. However, you likely won't get this functionality out-of-the box from your directory service. Here are a few best practices to help you comply with NIST's guidelines.

Check your users' passwords against an evolving list

Comparing passwords to a static list will not satisfy NIST's guidance. New breaches happen all the time, continually adding to your organization's risk exposure. To provide a sense of scale, SpyCloud researchers add about a billion new breach assets to our database every month.

It's not reasonable for most security teams to research and operationalize high volumes of breach data on their own. Organizations without a dedicated team to support this effort should evaluate vendors who can help. As you evaluate solution providers, look for a provider that collects new breach data regularly and provides a large database of plaintext passwords for you to check against your own user passwords. Also consider how the provider helps you put that data to use.

Ask potential solution providers:

- How often do you identify new breaches?
- How large is your database of breach records?
- How large is your database of plaintext passwords?
- How do you make breach data actionable for organizations?
- How do I use your solution to check for weak or exposed passwords?
- Do you offer a way to reset weak or exposed passwords automatically?

SpyCloud Tip

Put vendors to the test

The best way to evaluate a potential solution is by putting it to work through a proof of concept, or a head-to-head "data test" if you're comparing more than one vendor.

SPYCLOUD.COM

BEST PRACTICES FOR IMPLEMENTING NIST PASSWORD GUIDELINES | 8

Question time

- When you are designing your application, what is the maximum length of password you allow the user to have?

Length Password

```

46      alapdanceissomuchbetterwhenthestripperiscrying
46      perseusandtheseammonsterperseusandtheseammonster
45      tuhgsbemakinuottuhgsbemakinuottuhgsbemakinuot
45      MganificentBuxeMganificentBuxeMganificentBuxe
45      kiirosillyniynakiirosillyniynakiirosillyniyna
45      pnukgirl5121990pnukgirl5121990pnukgirl5121990
45      klilthepreppiesklilthepreppiesklilthepreppies
45      msrillamongosoemsrillamongosoemsrillamongosoe
45      hiuztilopochtlihiuztilopochtlihiuztilopochtli
45      Wth&amIDoingHereWth&amIDoingHereWth&amIDoingHere
45      CehrryDestroyerCehrryDestroyerCehrryDestroyer
45      GdoHatesACowardGdoHatesACowardGdoHatesACoward
45      MraiaCapitolinaMraiaCapitolinaMraiaCapitolina
45      MroeThanYouKonwMroeThanYouKonwMroeThanYouKonw
  
```



Create a password

Enter the password you would like to use with your account.

Passwords must have at least 8 characters and contain at least two of the following: uppercase letters, lowercase letters, numbers, and symbols.

.

Question time

- When you are designing your application, what is the maximum length of username you allow the user to have?



Agenda

- Functional Security Requirements
 - CIA
 - Authentication requirements
 - Authorization requirements
 - Accountability requirements
 - Other security requirement
- Artifact development
 - Abuse/mis-use cases